Cord Cleaning — Bug Fix & Change Log

Multitenant Cleaning Backend & Cleaning Frontend — Full audit and remediation pass

Branch: `staging` (both repos) · Backend commit: `71f7aeb` · Frontend commit: `22f4921` · Prepared: 2026-08-09

Contents

1. Feature work — Timesheet edited-hours tracking & admin re-edit
2. Production incident fix — HEIC/HEIF task-image upload failure
3. Backend — Critical severity fixes
4. Backend — High severity fixes
5. Backend — Medium severity fixes
6. Backend — Low severity fixes
7. Frontend — Critical severity fixes
8. Frontend — High severity fixes
9. Frontend — Medium severity fixes
10. Frontend — Low severity fixes
11. Deferred items — require a product/business decision or a larger refactor

1. Feature work — Timesheet edited-hours tracking & admin re-edit

Original request: when a supervisor's submitted hours are edited, show both the original ("what staff did") and the edited hours on the timesheet, and let admins/superadmins re-edit hours even after approval, since admins sometimes make mistakes.

REPO	FILE(S)	CHANGE
Backend	`V3_19__add_original_hours_to_staff_hours.sql`	New migration adding `edited`, `original_hours`, `original_check_in_out_activity`, `original_start_time`, `original_end_time` columns to `staff_hours`.
Frontend	`TimeSheet.tsx`	Displays original hours alongside edited hours; gates re-edit availability so admin/INTERNAL users can adjust hours after approval, not just before.

2. Production incident fix — HEIC/HEIF task-image upload failure

> **Reported error:** `IOException: Could not read image from uploaded file` at `ImageStampUtil.saveWithSydneyTimestamp`, thrown whenever a staff member uploaded a task photo taken directly from an iPhone.

Root cause: Java's built-in `ImageIO` has no decoder for HEIC/HEIF — the default photo format on iPhones since iOS 11. JPEG/PNG uploads were never affected; only photos picked straight from the iOS Photos app hit this.

> **Fix** (`ImageStampUtil.java`):
>
> - Detects HEIC/HEIF by its actual file signature (the ISO-BMFF `ftyp` box brand: `heic`, `heix`, `hevc`, `mif1`, etc.) rather than trusting the browser-supplied content-type or filename, both of which mobile uploads get wrong or omit.
> - When detected, shells out to `heif-convert` (from `libheif`) to convert the photo to JPEG in a temp file before handing it to `ImageIO` — the rest of the timestamp-stamping/thumbnailing pipeline is unchanged.
> - Added `libheif-examples` to the Docker runtime image (`Dockerfile`) so the `heif-convert` binary is actually present in the container.

Deployment note: this requires a Docker image rebuild and redeploy on the production server to take effect — code alone is not sufficient since the fix depends on the new `libheif-examples` package being present in the runtime image.

3. Backend — Critical severity fixes

AREA	ISSUE & FIX
Cross-tenant auth bypass	JWT-authenticated requests resolved which tenant schema to load the user from purely off client-supplied headers (`X-Tenant-ID` /Host), never checking that against the JWT's own `tenant` claim — an attacker with a valid token for Tenant A could authenticate as a same-username user in Tenant B. Fixed by adding `extractTenantUsingToken` , comparing it against the resolved schema in both `TenantJwtFilter` and `TenantInterceptor` , and rejecting mismatches with 401/403. Also fixed the JWT `tenant` claim itself to always carry the schema name (previously fell back to company name in some paths).
Invoice GST hardcoded at 10%	Invoice creation/update always used a hardcoded 10% GST rate while the PDF renderer used the tenant's real configured rate — the two could diverge, so the amount tracked as owed didn't match what was billed. `FinanceUtils` rewritten with rate-parameterized `calculateGst` / `splitGstInclusive` , threaded through invoice create/update/payment and finance reconciliation.
Broken repository methods	`TenantRolesRepository.findByCode` returned the wrong entity type; `IncidentManagementReportSummaryRepo.mainId` wasn't a valid Spring Data query — both were dead/unused, removed.
Unsanitized upload filename	`IncidentManagementServiceImpl.upload()` built the stored filename directly from the client-supplied name with no path-traversal guard. Now strips path segments via `Paths.get(...).getFileName()` and resolves against the intended upload directory.

4. Backend — High severity fixes

AREA	ISSUE & FIX
Tenant-context ordering	`ProfileServiceImpl.updateTenant()` cleared the tenant thread-local before the save that depended on it, silently writing to the `public` schema. Reordered and made `@Transactional`.
Tenant-context leak	`NotificationServiceImpl` switched to the `public` schema mid-request and never restored the caller's tenant, corrupting later queries in the same request. Wrapped in try/finally.
Ad-hoc timesheet link fragility	`editTimeChange` could silently drop the `staffHour` link on an already-approved ad-hoc row, risking duplicate `StaffHour` rows on next approval. Made the link update conditional on the request actually carrying a `staffHourId`.
Wrong join column	`CompanyMapper.getSupervisor`'s site-exclusion filter compared against a surrogate PK instead of the user id, so exclusions almost never applied. Corrected the join.
Hardcoded user id	`TenantAuthMapper.getProfile()` always returned the profile for user id 1 regardless of who was logged in. Parameterized by the actual user id.
Missing audit trail	`LeaveRequestServiceImpl.currentUserId()` always returned null, so leave requests/approvals had no `requestedBy` / `approvedBy`. Wired to the JWT-extracted user id.
Misleading method names	`CompanyServiceImpl`'s supervisor site-exclusion methods were correct in behavior but named backwards; renamed to `includeSupervisorSite` / `excludeSupervisorSite`. Also fixed `deleteSupervisor` to actually delete the fetched site-exclusion records (previously fetched and discarded), and a missing path separator in `addLogo` that left old logo files never cleaned up.
JWT filters crash on expired/malformed tokens	`TenantInterceptor`, `SuperAdminJwtFilter`, and the refresh-token endpoints threw raw exceptions (surfacing as 500s) instead of clean 401s whenever a token expired or was malformed — happened to every user roughly once a day. Wrapped in try/catch returning proper 401 responses.
Wrong expiry-day math	`DashboardController.getExpiryAlerts` used `Period.getDays()` (day-of-month component only) instead of a true day count, producing near-random compliance-alert numbers. Switched to `ChronoUnit.DAYS.between(...)`.
NPE on partial task photos	`GenerateReportPojo`'s setters crashed on a SQL `NULL` image list (a task with only before-photos, e.g.), breaking report PDF generation. Added null-guards.
Missing authorization checks	Added role checks across `SupervisorSalaryController`, `LeaveRequestController`, `SupervisorLeaveController`, `TimeChangeRequestController`, `SupervisorController`, `InvoiceImportController`, `TenantUserController.toggleStatus`, and all 9 endpoints of `StaffProfileController` (which previously let any authenticated user read/edit another staff member's bank details or ID documents by passing a different user id).
Chat auth & upload	`ChatController` trusted a JWT username with no expiry/tamper check; added `isTokenValidUsingToken` verification. `ChatMessageController`'s image upload had the same unsanitized-filename issue as the incident uploader; fixed the same way.

5. Backend — Medium severity fixes

AREA	ISSUE & FIX
Hardcoded credential	`TenantMailConfig.java` contained a hardcoded Gmail address and plaintext app password, unused by any active bean — deleted entirely.
AES-GCM IV reuse	`AesEncryptionDeCryption` always encrypted with an all-zero IV (used for tenant SMTP passwords and OTPs at rest). Rewritten to generate a random 12-byte IV per encryption, with a backward-compatible fallback so already-stored values still decrypt.
Broken SQL filters	`AdminUserMapper` filtered on `'STADD'` / `'STAFF'` instead of the real `'INTERNAL'` type and queried a nonexistent `roles` table, breaking `/admin/users/*`. `TenantUserRepository.findAllSupervisorsAndAdmin` was missing parentheses around an OR/AND, so deactivated admins still appeared in pickers. `LeaveRequestMapper` aliased three different columns to the same `staffName`, silently dropping requestedBy/approvedBy names. All corrected.
Inconsistent joins	`superadmin/TenantMapper.findAll()` used `LEFT JOIN tenant_domains` while `findById()` used a plain join, so a tenant with no domains configured would vanish from "get by id". Aligned.
Non-atomic document save	`TenantServiceImpl.addDocument` combined a JPA save, a raw JDBC update, and a file write outside a transaction — a partial failure left the three out of sync. Made `@Transactional`.
Path traversal risk	`FileServiceImpl` 's save/get/delete paths concatenated filenames without sanitization, and the traversal guard in `deleteFile` only logged instead of aborting. Added containment checks that actually throw/abort.
Unbounded external call	`SiteServiceImpl.externalApiToSaveLocation` called a third-party geocoding API with no timeout, able to stall every site create/update that included a location link. Added a 10s timeout with graceful fallback.
Unguarded Optional.get()	`MobileController` 's `checkIn` / `push` / `getLastLocation` threw raw `NoSuchElementException` for any `TenantUser` with no linked `Staff` row. Replaced with proper `AppException` -throwing guards.
Resource leak	`InvoiceExcelImportService` 's Excel `Workbook` was never closed on either import path. Wrapped both in try/finally.
Wrong JPA cardinality	`StaffHour` , `TimeShift` , `TimeShiftExtra` , `TimeChangeRequest` , `SiteTaskExecution` used `@OneToOne` for relationships that are actually many-to-one (repository-level workarounds already proved this). Corrected to `@ManyToOne(fetch = LAZY)` across all five entities; verified the app boots cleanly against the real schema afterward.

6. Backend — Low severity fixes

AREA	ISSUE & FIX
Logging	`GlobalExceptionHandler` used `ex.printStackTrace()` for every uncaught exception app-wide, bypassing normal logging. Switched to an SLF4J logger.
Wrong status code	`TenantController.getDocument` returned `200` with an empty body instead of `404` when no logo existed. Fixed to return `404`.
Dead code	Removed ~800 lines of dead, commented-out earlier query versions from `TimeShiftMapper.java` (four superseded revisions of the same query left in place).
Theoretical collision	`TimeSheetExcelServiceImpl.resolveStaffId` fell back to a `name.hashCode()`-derived synthetic id when a staff id was missing, risking two different unlinked staff merging into one payroll-export row. Switched the grouping key to a name-prefixed string, eliminating the collision risk.

7. Frontend — Critical severity fixes

AREA	ISSUE & FIX
Incident report id corruption	The injury-report wizard's document-upload step called `setIncidentId(id)` instead of `setDocumentId(id)`, overwriting the real incident id with the new document's id on every submission. The localStorage-sync effect was also missing `documentId` from its dependency array, and the terminal step's `navigate()` ran in the same tick as its state update, so the id sometimes never persisted at all before the wizard unmounted. Fixed the swapped setter, corrected the effect dependencies, and now writes the final id to localStorage directly before navigating (rather than relying on an effect that may never fire before unmount). Also fixed `ReportSummary.tsx`, which fell back to localStorage per-field even when a real incident row was passed in — meaning opening one incident right after creating another could silently show/edit the previous incident's linked records.
Hung token refresh queue	Both `apiClients.ts` (superadmin and tenant) queued concurrent 401'd requests while a token refresh was in flight, but only drained that queue on refresh *success* — on failure, every queued request's promise hung forever and the loading overlay could get stuck on screen permanently. Rebuilt the queue to carry resolve/reject pairs and drain (reject, with proper loading cleanup) on both outcomes.
Timesheet row id collisions	`TimeSheet.tsx`'s `getRowId` was built from `timeShiftId/date/staffId/siteId`, all of which are null for ad-hoc "extra site"/"extra staff" rows — two different ad-hoc entries on the same date resolved to the identical id, so selecting/editing one could silently affect the other. Extended the id to also include `requestId` / `staffhourid`, which are always unique per ad-hoc entry.

8. Frontend — High severity fixes

AREA	ISSUE & FIX
Wrong pagination math	The shared `Table.tsx` 's serial-number column used an unused, hardcoded `itemsPerPage = 5` instead of the real `rowsPerPage` state — every list past page 1 showed wrong row numbers. Fixed and removed the dead constant.
Route-param corruption	`encodeDecode.ts` 's base64 URL-safe swap used `.replace("/", "---")` with no `/g` flag, only swapping the first `/` — base64 output routinely contains several. Multi-slash payloads (common for embedded company/site objects) broke navigation. Added the flag to both encode and decode.
False "Tenant Not Active" screen	`LoginPage.tsx` treated `logoUrl === null` as "tenant inactive," which is also true while the logo request is still loading, and stayed true forever for a legitimate tenant that hadn't uploaded a logo (the backend logo endpoint always returns a real or default image on success — the only actual failure case is a genuinely inactive tenant). Switched the check to the query's own `error` / `loading` state.
Unauthenticated raw fetch()	New-supervisor company assignment used a raw `fetch()` bypassing the auth/refresh interceptor entirely, with a hardcoded `localhost:9898` fallback and no error handling — a failure mid-loop left the admin stuck with no feedback even though the user account was already created. Replaced with the app's authenticated mutation client, wrapped in `Promise.allSettled` so partial failures don't block the form from resetting/navigating.
Date-sort bug	`TimeAllocation.tsx` used the first-*clicked* date (not the earliest-*dated* one) as the baseline for computing recurring-shift day offsets, so any date at or before that arbitrary baseline collided with the baseline's own entries and overwrote shift data on save. Now sorts selected dates before picking the baseline.
Wrong navigation key	`ViewCompany.tsx` encoded the saved company object under `companyAddressReqPojo` but `SiteTabs.tsx` 's Back button checked for `companyAddressResPojo` — after any company edit, Back silently redirected to `/dashboard` instead of the company page. Changed the check to the company id, which is always present regardless of which address-field shape was encoded.
Sensitive data in URLs	Passwords and OTPs were sent as query-string parameters on `reset-password` , `verify-otp-forget-password` , `/users/change-password` , and `/profile/change-password` — visible in server access logs and browser history. Moved to request bodies on both frontend calls and the corresponding backend endpoints.

9. Frontend — Medium severity fixes

AREA	ISSUE & FIX
Live tracking WebSocket	`SiteMap.tsx` passed a freshly-mapped array into `GoogleMapTracking` on every render, and that array was a `useEffect` dependency controlling the STOMP WebSocket — the socket tore down and reconnected on every unrelated parent re-render, losing position updates each time. Memoized the array. Also added pruning so a staff member unassigned from a site has their stale marker removed instead of showing their last-known position forever.
Rendered JSX comments	`Map.tsx` had two `//` "comments" sitting as literal JSX text nodes (not real comments) directly inside `<GoogleMap>`, risking stray rendered text. Converted to real `{/* */}` JSX comments.
Stale "late check-in" status	`SiteList.tsx` computed "now" once via `useMemo(() => new Date(), [])` and never updated it, so a roster left open past a shift's start time never flipped to "not checked in." Switched to a 60s-interval refresh.
Wrong invoice summary	`InvoiceManagement.tsx`'s summary tiles re-filtered the already-cancelled-only list for non-cancelled rows when viewing the Cancelled tab, always showing $0.00. Sourced the summary from the full raw list instead of the tab-filtered one.
Stale PDF race condition	`InvoicePdfViewerModal.tsx` had no request-cancellation check — opening invoice A then quickly switching to invoice B before A's fetch resolved could let A's late response overwrite the PDF now showing for B. Added a ref tracking the currently-displayed invoice id and checked it before applying any fetch result.
Chat image leaks & unguarded publish	Staged chat-image previews called `URL.createObjectURL()` directly in the render body, minting a new never-revoked blob URL every re-render. Moved to a memoized/effect-cleaned set of preview URLs. Also added connectivity checks and try/catch around the STOMP `.publish()` calls for send/delete, which previously could silently no-op (leaving an already-uploaded image orphaned) or throw uncaught mid-send.
Off-by-one on site start date	`EditWork.tsx` shifted the site's start-date boundary back one day for click-through validation as well as calendar display, letting staff log task work one day before a site's official start. Split into two values — the true start date for validation, and a separate shifted value only for the calendar's exclusive-end display range.
Forms going blank after save	`BankDetailsForm.tsx`, `EmergencyContactForm.tsx`, and `OtherDetails.tsx` called a bare `reset()` on save success, which resets to the form's original empty defaults rather than the just-saved data — the form visibly went blank until the user navigated away and back. Switched to refetching the underlying query, which the existing populate-on-load effect already re-applies.
Divide-by-zero	`BudgetsList.tsx` divided by a site's `monthlyBudget` with no zero guard, rendering `Infinity%` / `NaN%` for a site with no budget set. Added a guard.
UTC/local date-filter bug	`IncidentManagement.tsx`'s date-range filter parsed "from"/"to" dates via `new Date("YYYY-MM-DD")`, which parses as UTC midnight — for AU's positive UTC offset that boundary lands mid-morning local time, silently excluding incidents created in the early hours of the selected "from" date. Now builds the boundary from local date components.

10. Frontend — Low severity fixes

AREA	ISSUE & FIX
Broken toggle styling	`RolePermission.tsx` (both superadmin and tenant copies) built a Tailwind class with `${COLORS.primary}` inside a plain (non-template) string, so it was never interpolated — the "Select All" toggle never showed its checked-state color. Fixed with a literal static class.
Dead onChange handler	`AdminProfile.tsx`'s tax-type label never updated because the change handler was attached to `<option>` instead of `<select>` (never fires in any browser). Removed the dead handler and derived the label from the form's live watched value instead.
Blob URL leak	`LogoContext.tsx` created an object URL via `useMemo`, which has no cleanup hook, so the previous blob URL was never revoked on refetch. Switched to `useEffect` with proper revocation.
No-op button	`TransactionsList.tsx`'s "Export Ledger" button had no click handler at all. Wired up a client-side CSV export of the currently-loaded ledger entries.
Missing React keys	`TimeAllocation.tsx` mapped staff columns via unkeyed JSX fragments, risking React misassigning one staff member's cells to another's column on reorder. Added keys via `React.Fragment`.
Silent failure	`AddIncident.tsx` had an empty catch block on its first API call. Added error logging for debuggability (a toast was already shown by the shared interceptor).
Stale document preview	`ProfileDocumentUpload.tsx`'s upload mutation had no refetch on success, so the "existing file" preview didn't update until the user left and returned to the tab. Added a refetch.
Cosmetic	`ExpenseManagement.tsx` had stray literal text (`Dashboard Awareness`) accidentally baked into a Tailwind `className` string. Removed.

11. Deferred items — require a product decision or a larger refactor

These were identified during the audit but deliberately **not** auto-fixed, either because they need a business decision this document can't make, or because a safe fix requires a change large/risky enough to warrant its own planned piece of work.

- **SiteInspectionController** — no role restriction added on inspection approve/reject; unclear whether CLIENT users should be allowed to sign off (the entity carries a `clientName` field suggesting maybe).
- **Money stored as `Double`, not `BigDecimal`** — across `Invoice` / `InvoiceLineItem` / `FinanceLedgerEntry` / `BankTransaction`, inconsistent with the rest of the codebase. Correct fix, but a large, regression-risky refactor touching most of the finance module.
- **Duplicated pay-rate SQL** — the same day-of-week rate `CASE` logic (missing public-holiday rate handling) is copy-pasted across three different mappers. Consolidating needs careful cross-mapper regression testing.
- **ExpenseServiceImpl never computes GST** — there is no `taxable` field on the underlying data model at all; this is a feature addition (new field + UI), not a bug fix.
- **Two competing signup pages** (`SignUpPage.tsx` vs the actually-reachable `Register.tsx`) — which one is canonical is a product decision.
- **eLearning module** (`CourseList.tsx` / `CoursePlayer.tsx`) — confirmed fully mocked: enrollment, quiz results, and progress tracking don't persist anywhere. Needs real implementation, not a bug fix.
- **BankReconciliation.tsx's "Include GST" toggle** — purely cosmetic; the backing DTO has no fields for it at all, so a real fix needs a backend change too.
- **ChatRoom pagination** — the backend has no paging support whatsoever (fetches the entire message history every time); a proper fix needs new backend endpoint work (page/size params, "seen" tracking semantics), not just a frontend change.
- **OTP/reset-password hardening** — no rate limiting on verify/resend, OTP comparison isn't constant-time, and the final reset step doesn't re-check expiry. Security-posture questions needing agreed rate limits, not single-line fixes.
- **Miscellaneous fragile-but-currently-working items left alone** to avoid regression risk: the `BCryptPasswordEncoder` bean that's wired implicitly rather than explicitly; a wildcard-matching mismatch between two different consumers of `SecurityUtilAdmin.skipUrls`; the shared DB sequence generator name between `TimeShift` and `TimeShiftExtra` (cosmetic only — both still get unique ids); the repeated `tenantDetailsRepository.findAll().get(0)` pattern used app-wide.

Generated as a record of the audit-and-fix pass performed on the `staging` branch of both repositories. Backend verified booting cleanly against the live database after all changes; frontend verified with a full `tsc -b` type-check pass (zero errors).